

# THREAT INTELLIGENCE REPORT

THREAT ACTOR PROFILE: APT28 (FANCY BEAR)

Russian General Staff Main Intelligence Directorate (GRU)

Classification: TLP WHITE

Date: 29<sup>th</sup> June 2026

Prepared by: Rakesh R

Sources: MITRE ATT&CK | CROWD STRIKE | VOLEXITY | US DOJ |

**Table of Contents:**

|                                      |   |
|--------------------------------------|---|
| 1. Executive Summary                 | 3 |
| 2. Attribution and Background        | 3 |
| 3. Target profile                    | 4 |
| 4. Tactics Techniques and Procedures | 5 |
| 5. Notable Campaigns                 | 6 |
| 6. Defensive recommendation          | 7 |
| 7. References                        | 8 |

## Executive Summary:

APT28 is also known as Fancy Bear is a state-sponsored threat actor attributed to Russia's General Staff Main Intelligence Directorate. Active since 2004, the group has conducted sustained espionage operations targeting governmental organisations, diplomatic entities and civil society groups primarily across NATO member states, Europe and the United States. Unlike financially motivated cyber criminals groups, APT28's objective is rooted in espionage and political influence. Their goal is to steal sensitive information and use it as a weapon rather than financial gain. The group is linked to high-profile operations like interference in European electoral processes. APT28 represents a persistent and evolving threat that operates with state-level resources making them geopolitically significant threat actors currently active.

## Attribution and Background:

Threat actor APT28 is known by multiple aliases by multiple intelligence and cybersecurity organisations, resulting in a range of designations that all refer to the same group.

| Vendor       | Name for APT28 |
|--------------|----------------|
| MITRE ATT&CK | APT28          |
| CrowdStrike  | Fancy Bear     |
| Microsoft    | STRONTIUM      |
| Mandiant     | APT28          |
| Kaspersky    | Sofacy         |

Multiple nations have attributed the apt 28 with the russian government to the Russia's GRU (military unit 26165) operates as the 85th Main Special Service Center (GTsSS) including germany united kingdom united states and poland & NATO.

**Attribution Assessment:** Multiple Indicators supports the attribution of the activity to Russian state aligned threat actor. The adversary's command-and-control (C2) infrastructure is linked to Russian-hosted IP addresses, attack telemetry consistently aligns with Moscow working hours, and Russian-language artifacts were identified within the malware, suggesting a Russian-speaking development and operational environment. In 2018, the US Department of Justice formally indicted seven GRU officers by name, representing one of the strongest public attribution actions ever taken against a state-sponsored threat actor.

**Targeting Assessment:** The victimology associated with APT28 primarily consists of defense organizations, government institutions, and policy-related entities. This targeting pattern is consistent with Russian strategic intelligence objectives, particularly during the Russia-Ukraine conflict and in relation to NATO member states and allied governments. The campaign appears to support geopolitical intelligence collection aligned with Russian national interests.

## Target Profile:

The targeting profile of APT28 is directly aligned with Russian state intelligence priorities, focusing on nations and organizations whose data, infrastructure, and communications hold geopolitical value to the Russian government.

| Category          | Countries and Entities                                             |
|-------------------|--------------------------------------------------------------------|
| Primary Targets   | Ukraine, USA, UK, Germany, Poland, NATO                            |
| Secondary Targets | Australia, Brazil, South Korea                                     |
| Key Sectors       | Government, Military, Energy, Rail & Logistics, Media              |
| Data of Interest  | Diplomatic cables, Military plans, Election data, Policy documents |

Following the escalation of the Russia–Ukraine conflict in February 2022, APT28 significantly intensified its operations against Ukrainian government institutions, military organizations, and critical infrastructure including energy grids and rail logistics networks. NATO member states supplying military aid to Ukraine also experienced a marked increase in cyber intrusions, with APT28 targeting defense ministries, government communications, and military supply chain organizations to collect intelligence on Western support efforts. The theft of military operational plans, diplomatic communications, and defense policy documents during this period further corroborates APT28's direct alignment with Russian state intelligence priorities and its role as an instrument of Russian geopolitical strategy.

## **Tactics Techniques and Procedures:**

APT28 typically initiates intrusions through targeted spearphishing campaigns, delivering malicious attachments disguised as legitimate documents such as NATO briefings, government communications, or diplomatic correspondence to increase the likelihood of victim engagement. Once a foothold is established, the group leverages PowerShell scripts for execution, allowing them to operate using built-in system tools that are less likely to trigger security alerts. To maintain persistent access within compromised environments, APT28 deploys scheduled tasks and modifies registry run keys, ensuring their presence survives system reboots and routine security scans.

To harvest credentials within compromised networks, APT28 employs two primary methods — dumping the LSASS process memory to extract NTLM hashes, Kerberos Ticket Granting Tickets (TGTs), and plain text passwords, and conducting password spraying attacks against government email systems. The group utilizes HTTPS beaconing for command and control communication, deliberately blending malicious traffic with legitimate web traffic to evade network detection. Collected data is exfiltrated through the same encrypted C2 channel, making it difficult for defenders to distinguish malicious outbound traffic from normal activity. This methodical approach from initial access through to exfiltration reflects the operational sophistication of a state-sponsored threat actor.

| Tactic            | Technique ID | Technique Name               | Procedure                                         |
|-------------------|--------------|------------------------------|---------------------------------------------------|
| Initial Access    | T1566.001    | Spearphishing Attachment     | Phishing email containing malicious document      |
| Initial Access    | T1078        | Valid Accounts               | Using stolen credentials to access victim systems |
| Execution         | T1059.001    | PowerShell                   | PowerShell spawned by Office process              |
| Persistence       | T1053.005    | Scheduled Task               | Malicious scheduled tasks created for persistence |
| Persistence       | T1547.001    | Registry Run Keys            | Malware added to registry for automatic execution |
| Credential Access | T1003        | OS Credential Dumping        | LSASS memory access to harvest credentials        |
| Credential Access | T1110.003    | Password Spraying            | Brute force against government email systems      |
| Command & Control | T1071.001    | Web Protocols                | HTTPS beaconing to C2 infrastructure              |
| Exfiltration      | T1041        | Exfiltration Over C2 Channel | Encrypted data sent to remote server              |

## Notable Campaigns:

**Nearest Neighbour Attack** : In February 2024, cybersecurity firm Volexity uncovered a highly sophisticated APT28 intrusion campaign that introduced a novel technique now known as the Nearest Neighbour Attack. Unable to directly breach the target network remotely, APT28 compromised a separate organisation located within WiFi range of their intended victim in Washington DC, then pivoted through that organisation's infrastructure to reach the target network via WiFi daisy chaining – effectively conducting a physical proximity attack from over 1000 miles away. This technique allowed the threat actor to appear as a legitimate local network user, bypassing remote access controls that would have detected an external intrusion. The campaign targeted government, defence, and military related organisations across Ukraine, Moldova, Belarus, Poland, the UK, France, Georgia, and other NATO-aligned nations. The Nearest Neighbour Attack is considered significant because it demonstrated that physical proximity to a target could be achieved entirely through cyber means, representing a new class of intrusion technique with serious implications for network security.

**2016 Democratic National Committee (DNC) hack :** In 2016, CrowdStrike identified two separate APT groups operating within the Democratic National Committee (DNC) network, with APT28 confirmed as having maintained access since mid-2015. The intrusion was initiated through spearphishing emails disguised as legitimate Google security alerts, tricking staff into surrendering their credentials through spoofed Gmail login pages. APT28 deployed two signature malware tools – X-Agent, a keylogger used to capture keystrokes and exfiltrate files, and X-Tunnel, which provided encrypted communication channels to their C2 infrastructure. The stolen data, comprising thousands of internal emails and communications, was subsequently leaked publicly through DCLeaks and Wikileaks, revealing that DNC leadership had favored Hillary Clinton over Bernie Sanders during the presidential primary. The political fallout resulted in the resignation of DNC Chairwoman Debbie Wasserman Schultz, and in 2018 the US Department of Justice formally indicted 12 GRU officers by name for their direct involvement in this operation.

## **Defensive Recommendations:**

**Technical Controls:** Given APT28's reliance on living-off-the-land techniques and credential theft, organisations should prioritise several technical controls to reduce their attack surface. PowerShell execution should be restricted through Constrained Language Mode and Script Block Logging, preventing unauthorized scripts from running within user environments. LSASS credential dumping can be mitigated by enabling Credential Guard and Protected Process Light (PPL), which isolate the LSASS process from unauthorized memory access. EDR solutions should be configured to alert on credential dumping behaviour in real time. Additionally, implementing least privilege access principles ensures that even if credentials are compromised, the attacker's ability to move laterally across the network remains significantly limited.

**Human Controls:** Beyond technical controls, organisations must address the human element that APT28 consistently exploits. Regular security awareness training should be conducted to educate staff on identifying spear phishing emails, suspicious attachments, and spoofed login pages – the exact techniques APT28 uses to gain initial access. Email filtering solutions should be deployed to quarantine malicious content before it reaches end users. Strong password policies combined

Multi-Factor Authentication (MFA) and rate limiting on login attempts significantly reduce the effectiveness of APT28's password spraying campaigns.

| TTP                      | Defensive Control                                                          |
|--------------------------|----------------------------------------------------------------------------|
| Spearphishing            | Security awareness training, email filtering, attachment sandboxing        |
| PowerShell Execution     | Constrained Language Mode, Script Block Logging, restrict unsigned scripts |
| LSASS Credential Dumping | Credential Guard, Protected Process Light (PPL), EDR alerting              |
| HTTPS Beaconing          | SSL/TLS metadata inspection, DNS monitoring, EDR process behaviour rules   |
| Password Spraying        | MFA, rate limiting, conditional access policies                            |

## References:

1. [MITRE ATT&CK](#)
2. [Volexity Blog](#)
3. [DOJ – Press Release](#)
4. [CrowdStrike Profile](#)
5. [Microsoft – STRONTIUM –Report](#)